Don’t Pay The Reaper: File Share Security Against Ransomware

trimarcsecurity.com/hub-post/don-t-pay-the-reaper-file-share-security-against-ransomware

Sean Burgess October 18, 2022

Updated: Dec 13, 2024

Introduction

Ransomware? In MY files shares? It’s more likely than you think. According to an August 2021 report from the Cybersecurity & Infrastructure Security Agency (CISA):

“The number of ransomware incidents also continues to rise, with **2,474** incidents reported in 2020, representing a **20%** increase in the number of incidents, and a **225%** increase in ransom demands. From January to July 31, 2021, the IC3 has received **2,084** ransomware complaints with over **$16.8M in losses**, a **62%** increase in reporting and **20%** increase in reported losses compared to the same time frame in 2020.” - CISA Alert (AA21-243A)

Nobody wants to pay ransomware; we all have better ways to spend our money. Eventually the new Game of Thrones books will come, and we need to be prepared. The good news is that there is a lot that you can do to reduce the potential hit to your bottom line. The purpose of this blog isn’t how to stop a ransomware infection.

The unfortunate reality is that ransomware is a booming criminal enterprise that shows no signs of slowing down. There will always be new ransomware tools for malicious actors to use against you, and the likelihood that you will face a ransomware attack can never be fully ruled out. Instead, this blog offers methods to mitigate the impact of an infection and help you avoid paying the ransom if and when you do find yourself in this unfortunate predicament.

Cost Benefit Analysis

How much production time will you lose if you don’t pay? How much existing work will be lost forever? How much confidential client data will be compromised? You may believe that frequent and reliably tested backups are enough, but this is not entirely true. While backups are a great way to hedge against the cost of losses, they must be paired with proper storage strategies.

After your network is hit with ransomware, you have a choice. Do you do a full recovery of all the impacted volumes and lose any work done since the last good backup, or do you perform a comparative restore that will keep your existing good data and restore only the ransomed files? This process recovers the most data but take much longer to complete.

The answer to that question should depend on the cost of a lost day of work versus the cost of the diminished productivity while files are more slowly recovered. In many cases a full recovery is the best choice. A comparative restore can take days or even weeks to complete depending on how many files were affected, but what if there was a way to speed up the recovery process significantly and still get all your files back?

What are you backing up? What are you willing to lose?

In a modern network, you are likely backing up operating systems, file shares, virtual disks, cloud storage, or databases. Each type of backup has its own subtleties; today we are going to focus on file shares. Shares are often the most difficult to completely recover in an expedient manner. The effectiveness of file share backups are, in many ways, dependent on the size of the share, the number of files, and the number of users with write/modify access to the share.

A total recovery of affected file storage is often quicker than a comparative restore because it processes the data by block instead of by file. However, any changes made between the last good backup and the point of restoration will be lost. In contrast, a comparative restore not only needs to restore by file, it also includes error checking to make sure nothing is missed.

In a comparative restore, the best way to reduce total recovery time is to reduce the number of files that must be restored. The typical comparative restore process can take 1 second per file with potential retries consuming up to 5 seconds per file.

The chart below shows a sample of estimated restore times based on the number of files in an infected share and the percentage of infected files.

Comparative Restore Estimation Table

Total Number of Files in a Share	Infection Rate	Total Recovery Time in Hours
500000	70%	97.2
400000	70%	77.8
300000	70%	58.3
200000	70%	38.9
100000	70%	19.4
500000	60%	83.3
400000	60%	66.7
300000	60%	50
200000	60%	33.3
100000	60%	16.7
500000	50%	69.4
400000	50%	55.6
300000	50%	41.7
200000	50%	27.8
100000	50%	13.9

Note: These estimates are on the low end. It often takes additional trial and error to get everything back to normal as missing and/or problematic files are inevitable during a major backup recovery operation.

Taking Action: Reducing the files that need to be recovered without shrinking your total file count.

Now we can start to take some action. Here are the steps you can begin to implement today to secure your file shares from a ransomware attack.

1. System Operations should control file shares, not users. Users should not be able to create shares and sub-shares directly or even through simple service desk tickets. Instead, the IT department should be planning shares in coordination with department heads because IT leadership is ultimately responsible for file management and recovery. Your file shares are not a circus, and they will get out of control quickly if you let them.



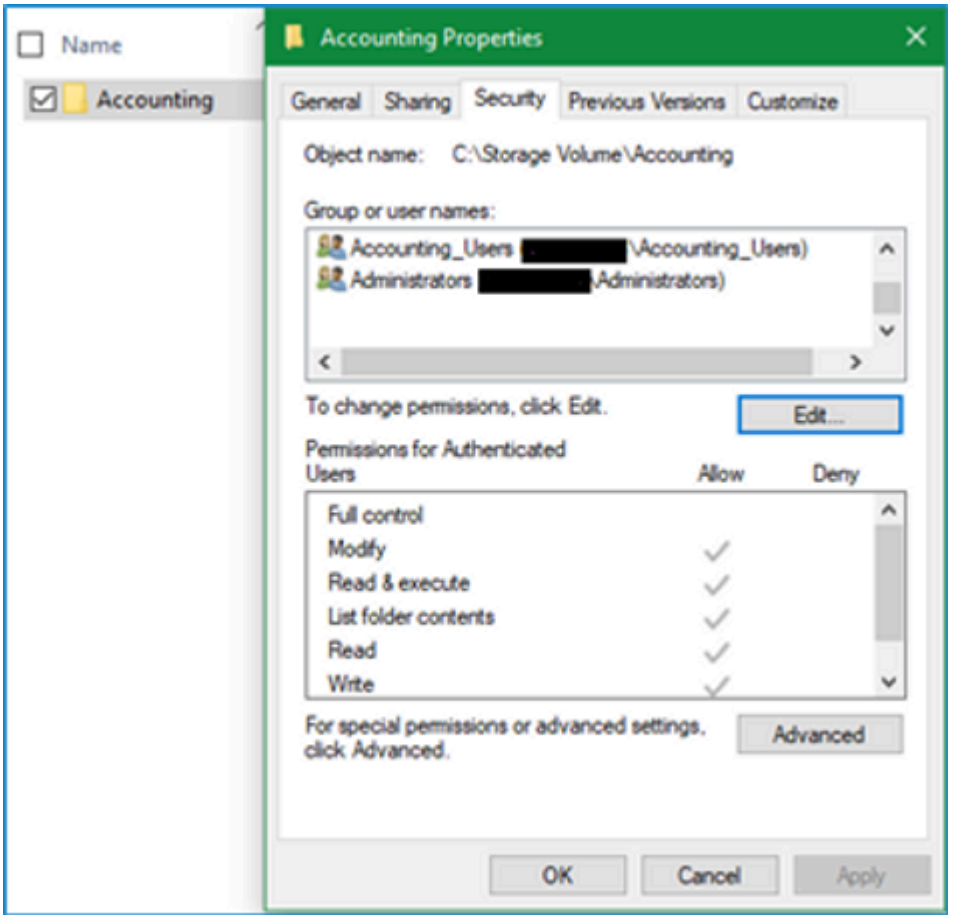
2. Reduce the number of users who have access to a particular file share. Typically, it's best to have a single share for each department and even better to have a share for each sub-department. If the legal department has a budgeting sub department, give them each a separate share. Nested shares are a terrible idea and a great way to wind up with overly permissive file access.



3. Restrict access to file shares with NTFS privileges. Do not control access through share permissions. This may seem counterintuitive since you are managing shares but this simple step will prevent mixed access control strategies from undermining your security posture. NTFS should be an implicit deny while share permissions should be an implicit allow. This keeps all the settings in one place and prevents confusion that can lead to vulnerabilities. Far too many organizations have overly permissive security settings in NTFS and additional restrictions in the direct share permissions that make managing security a nightmare.



4. Use security groups to manage file share access. Do not give individual users direct privileges to shares. If a user needs access to multiple shares they can be in multiple security groups. The less files a single user has access to, the less files they can infect.



5. Put each share on its own virtual disk or container. Overly permissive access to the disk or container can lead to compromise of the shares within. Reducing the number of shares per virtual disk or container reduces the risk of total compromise and makes it easier to plan for storage growth in the future. It will also allow for the total restore of a single share without affecting any others. Each department may have different requirements for data recovery. Only the system operators should have permissions to the virtual disk or

container and that container should be managed by the security group. When it comes to data, think silos not free range.



You’re ready for a quick recovery, but how can you avoid paying the blackmail?

Blackmail is often a second thought after a successful ransomware attack, but double-extortion is fast becoming the standard mode of operation for ransomware gangs. With proper backup and recovery procedures in place, an attacker will not be able to hold your files hostage, but they can still threaten to release confidential files into the public or sell them for a profit. Fortunately, there is a simple precaution to avoid this issue.

Encrypt your confidential files

While ransomware can doubly-encrypt already-encrypted files, proper encryption makes double-extortion a money-losing proposition in a couple ways. First, attackers won’t be able to read any properly encrypted files they steal, and files that cannot be read are files that cannot be sold. Additionally, while attackers can theoretically decrypt your confidential files given enough time, the associated costs make decryption financially infeasible for all but the most sensitive data. Remember that the goal of ransomware is to make money. Taking steps to make a ransomware gang's job more costly makes you a less-attractive target.

Identify and encrypt your confidential data today, and make sure any encryption tools you use keep up with modern encryption protocols and support stronger encryption keys. Encrypting your most confidential files will not prevent a ransomware attack, but it will minimize the financial and reputational impact of the incident.

Let’s review

Ransomware attacks are still on the rise and show no signs of slowing down. If there is money to be made, secrets to be exposed, and PII to be stolen, the best offense is a well thought out defense. In this blog we’ve covered a lot about file share security strategy, including:

• Planning your file shares ahead of time to work with your backups.

• Avoiding nested shares.

• Using NTFS instead of share permissions for Access Control.

• Managing NTFS privileges with security groups.

• Using virtual disks or containers to separate shares.

• Never setting standard user permissions at the disk/container level.

• Encrypting confidential or sensitive data.

The through-line of these suggestions is to keep your total file count segmented into small easy to restore blocks so recovery can be relatively quick and painless. More shares are better than big shares. The Reaper comes to collect, but crime doesn’t pay if you are prepared.

Trimarc Identity Team

About Trimarc Security

Trimarc are the Active Directory experts. We have a number of professional services to help you harden your Active Directory, Azure AD, and VMWare environments along with your general security posture against malicious actors. The Trimarc Security Enterprise Security Program (ESP) assessment will review some of the concepts discussed in this article along with a myriad of other valuable insights. You can explore these services at our official site https://www.trimarcsecurity.com.


TRIMARC